

Windows Remote Management Protocols

Windows servers can be managed locally using Server Manager administration tasks on remote servers. Remote management is enabled by default starting with Windows Server 2016. Remote management is a component of the Windows hardware management features that manage server hardware locally and remotely. These features include a service that implements the WS-Management protocol, hardware diagnostics and control through baseboard management controllers, and a COM API and script objects that enable us to write applications that communicate remotely through the WS-Management protocol.

The main components used for remote management of Windows and Windows servers are the following:

- Remote Desktop Protocol (RDP)
- Windows Remote Management (WinRM)
- Windows Management Instrumentation (WMI)

RDP

The Remote Desktop Protocol (RDP) is a protocol developed by Microsoft for remote access to a computer running the Windows operating system. This protocol allows display and control commands to be transmitted via the GUI encrypted over IP networks. RDP works at the application layer in the TCP/IP reference model, typically utilizing TCP port 3389 as the transport protocol. However, the connectionless UDP protocol can use port 3389 also for remote administration.

For an RDP session to be established, both the network firewall and the firewall on the server must allow connections from the outside. If Network Address Translation (NAT) is used on the route between client and server, as is often the case with Internet connections, the remote computer needs the public IP address to reach the server. In addition, port forwarding must be set up on the NAT router in the direction of the server.

RDP has handled Transport Layer Security (TLS/SSL) since Windows Vista, which means that all data, and especially the login process, is protected in the network by its good encryption. However, many Windows systems do not insist on this but still accept inadequate encryption via RDP Security. Nevertheless, even with this, an attacker is still far from being locked out because the identity-providing certificates are merely self-signed by default. This means that the client cannot distinguish a genuine certificate from a forged one and generates a certificate warning for the user.

The Remote Desktop service is installed by default on Windows servers and does not require additional external applications. This service can be activated using the Server Manager and comes with the default setting to allow connections to the service only to hosts with Network level authentication (NLA).

Footprinting the Service

Scanning the RDP service can quickly give us a lot of information about the host. For example, we can determine if NLA is enabled on the server or not, the product version, and the hostname.

Nmap

Nmap

```
dbcyph0n@htb[/htb]$ nmap -sV -sC 10.129.201.248 -p3389 --script rdp*

Starting Nmap 7.92 ( https://nmap.org ) at 2021-11-06 15:45 CET
Nmap scan report for 10.129.201.248
Host is up (0.036s latency).

PORT      STATE SERVICE      VERSION
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
| rdp-enum-encryption:
|   Security layer
|     CredSSP (NLA): SUCCESS
|     CredSSP with Early User Auth: SUCCESS
|_  RDSTLS: SUCCESS
| rdp-ntlm-info:
|   Target_Name: ILF-SQL-01
|   NetBIOS_Domain_Name: ILF-SQL-01
|   NetBIOS_Computer_Name: ILF-SQL-01
|   DNS_Domain_Name: ILF-SQL-01
|   DNS_Computer_Name: ILF-SQL-01
|   Product_Version: 10.0.17763
|_  System_Time: 2021-11-06T13:46:00+00:00
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.26 seconds
```

In addition, we can use `--packet-trace` to track the individual packages and inspect their contents manually. We can see that the `RDP cookies (msthash=nmap)` used by Nmap to interact with the RDP server can be identified by `threat hunters` and various security services such as `Endpoint Detection and Response (EDR)`, and can lock us out as penetration testers on hardened networks.

Nmap

```

dbcyph0n@htb[/htb]$ nmap -sV -sC 10.129.201.248 -p3389 --packet-trace --disable-arp-ping -n

Starting Nmap 7.92 ( https://nmap.org ) at 2021-11-06 16:23 CET
SENT (0.2506s) ICMP [10.10.14.20 > 10.129.201.248 Echo request (type=8/code=0) id=8338 seq=0] IP [ttl=53 id=5122
SENT (0.2507s) TCP 10.10.14.20:55516 > 10.129.201.248:443 S ttl=42 id=24195 iplen=44 seq=1926233369 win=1024 <ms
SENT (0.2507s) TCP 10.10.14.20:55516 > 10.129.201.248:80 A ttl=55 id=50395 iplen=40 seq=0 win=1024
SENT (0.2517s) ICMP [10.10.14.20 > 10.129.201.248 Timestamp request (type=13/code=0) id=8247 seq=0 orig=0 recv=0
RCVD (0.2814s) ICMP [10.129.201.248 > 10.10.14.20 Echo reply (type=0/code=0) id=8338 seq=0] IP [ttl=127 id=38158
SENT (0.3264s) TCP 10.10.14.20:55772 > 10.129.201.248:3389 S ttl=56 id=274 iplen=44 seq=2635590698 win=1024 <mss
RCVD (0.3565s) TCP 10.129.201.248:3389 > 10.10.14.20:55772 SA ttl=127 id=38162 iplen=44 seq=3526777417 win=64000
NSOCK INFO [0.4500s] nsock_iod_new2(): nsock_iod_new (IOD #1)
NSOCK INFO [0.4500s] nsock_connect_tcp(): TCP connection requested to 10.129.201.248:3389 (IOD #1) EID 8
NSOCK INFO [0.4820s] nsock_trace_handler_callback(): Callback: CONNECT SUCCESS for EID 8 [10.129.201.248:3389]
Service scan sending probe NULL to 10.129.201.248:3389 (tcp)
NSOCK INFO [0.4830s] nsock_read(): Read request from IOD #1 [10.129.201.248:3389] (timeout: 6000ms) EID 18
NSOCK INFO [6.4880s] nsock_trace_handler_callback(): Callback: READ TIMEOUT for EID 18 [10.129.201.248:3389]
Service scan sending probe TerminalServerCookie to 10.129.201.248:3389 (tcp)
NSOCK INFO [6.4880s] nsock_write(): Write request for 42 bytes to IOD #1 EID 27 [10.129.201.248:3389]
NSOCK INFO [6.4880s] nsock_read(): Read request from IOD #1 [10.129.201.248:3389] (timeout: 5000ms) EID 34
NSOCK INFO [6.4880s] nsock_trace_handler_callback(): Callback: WRITE SUCCESS for EID 27 [10.129.201.248:3389]
NSOCK INFO [6.5240s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 34 [10.129.201.248:3389] (19
Service scan match (Probe TerminalServerCookie matched with TerminalServerCookie line 13640): 10.129.201.248:3389

...SNIP...

NSOCK INFO [6.5610s] nsock_write(): Write request for 54 bytes to IOD #1 EID 27 [10.129.201.248:3389]
NSE: TCP 10.10.14.20:36630 > 10.129.201.248:3389 | 00000000: 03 00 00 2a 25 e0 00 00 00 00 00 43 6f 6f 6b 69 *
00000010: 65 3a 20 6d 73 74 73 68 61 73 68 3d 6e 6d 61 70 e: mstshash=nmap
00000020: 0d 0a 01 00 08 00 0b 00 00 00

...SNIP...

NSOCK INFO [6.6820s] nsock_write(): Write request for 57 bytes to IOD #2 EID 67 [10.129.201.248:3389]
NSOCK INFO [6.6820s] nsock_trace_handler_callback(): Callback: WRITE SUCCESS for EID 67 [10.129.201.248:3389]
NSE: TCP 10.10.14.20:36630 > 10.129.201.248:3389 | SEND
NSOCK INFO [6.6820s] nsock_read(): Read request from IOD #2 [10.129.201.248:3389] (timeout: 5000ms) EID 74
NSOCK INFO [6.7180s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 74 [10.129.201.248:3389] (211
NSE: TCP 10.10.14.20:36630 < 10.129.201.248:3389 |
00000000: 30 81 d0 a0 03 02 01 06 a1 81 c8 30 81 c5 30 81 0 0 0
00000010: c2 a0 81 bf 04 81 bc 4e 54 4c 4d 53 53 50 00 02 NTLMSSP
00000020: 00 00 00 14 00 14 00 38 00 00 00 35 82 8a e2 b9 8 5
00000030: 73 b0 b3 91 9f 1b 0d 00 00 00 00 00 00 00 70 s p
00000040: 00 70 00 4c 00 00 00 0a 00 63 45 00 00 00 0f 49 p L cE I
00000050: 00 4c 00 46 00 2d 00 53 00 51 00 4c 00 2d 00 30 L F - S Q L - 0
00000060: 00 31 00 02 00 14 00 49 00 4c 00 46 00 2d 00 53 1 I L F - S
00000070: 00 51 00 4c 00 2d 00 30 00 31 00 01 00 14 00 49 Q L - 0 1 I
00000080: 00 4c 00 46 00 2d 00 53 00 51 00 4c 00 2d 00 30 L F - S Q L - 0
00000090: 00 31 00 04 00 14 00 49 00 4c 00 46 00 2d 00 53 1 I L F - S
000000a0: 00 51 00 4c 00 2d 00 30 00 31 00 03 00 14 00 49 Q L - 0 1 I
000000b0: 00 4c 00 46 00 2d 00 53 00 51 00 4c 00 2d 00 30 L F - S Q L - 0
000000c0: 00 31 00 07 00 08 00 1d b3 e8 f2 19 d3 d7 01 00 1
000000d0: 00 00 00

...SNIP...

```

A Perl script named [rdp-sec-check.pl](#) has also been developed by [Cisco CX Security Labs](#) that can unauthentically identify the security settings of RDP servers based on the handshakes.

RDP Security Check - Installation

RDP Security Check - Installation

```
dbcyp0n@htb[/htb]$ sudo cpan
```

```
Loading internal logger. Log::Log4perl recommended for better logging
```

```
CPAN.pm requires configuration, but most of it can be done automatically.  
If you answer 'no' below, you will enter an interactive dialog for each  
configuration option instead.
```

```
Would you like to configure as much as possible automatically? [yes] yes
```

```
Autoconfiguration complete.
```

```
commit: wrote '/root/.cpan/CPAN/MyConfig.pm'
```

```
You can re-run configuration any time with 'o conf init' in the CPAN shell
```

```
cpan shell -- CPAN exploration and modules installation (v2.27)  
Enter 'h' for help.
```

```
cpan[1]> install Encoding::BER
```

```
Fetching with LWP:
```

```
http://www.cpan.org/authors/01mailrc.txt.gz
```

```
Reading '/root/.cpan/sources/authors/01mailrc.txt.gz'
```

```
.....DONE
```

```
...SNIP...
```

RDP Security Check

RDP Security Check

```
dbcyp0n@htb[/htb]$ git clone https://github.com/CiscoCXSecurity/rdp-sec-check.git && cd rdp-sec-check
dbcyp0n@htb[/htb]$ ./rdp-sec-check.pl 10.129.201.248

Starting rdp-sec-check v0.9-beta ( http://labs.portcullis.co.uk/application/rdp-sec-check/ ) at Sun Nov  7 16:50:

[+] Scanning 1 hosts

Target:    10.129.201.248
IP:        10.129.201.248
Port:      3389

[+] Checking supported protocols

[-] Checking if RDP Security (PROTOCOL_RDP) is supported...Not supported - HYBRID_REQUIRED_BY_SERVER
[-] Checking if TLS Security (PROTOCOL_SSL) is supported...Not supported - HYBRID_REQUIRED_BY_SERVER
[-] Checking if CredSSP Security (PROTOCOL_HYBRID) is supported [uses NLA]...Supported

[+] Checking RDP Security Layer

[-] Checking RDP Security Layer with encryption ENCRYPTION_METHOD_NONE...Not supported
[-] Checking RDP Security Layer with encryption ENCRYPTION_METHOD_40BIT...Not supported
[-] Checking RDP Security Layer with encryption ENCRYPTION_METHOD_128BIT...Not supported
[-] Checking RDP Security Layer with encryption ENCRYPTION_METHOD_56BIT...Not supported
[-] Checking RDP Security Layer with encryption ENCRYPTION_METHOD_FIPS...Not supported

[+] Summary of protocol support

[-] 10.129.201.248:3389 supports PROTOCOL_SSL      : FALSE
[-] 10.129.201.248:3389 supports PROTOCOL_HYBRID: TRUE
[-] 10.129.201.248:3389 supports PROTOCOL_RDP     : FALSE

[+] Summary of RDP encryption support

[-] 10.129.201.248:3389 supports ENCRYPTION_METHOD_NONE      : FALSE
[-] 10.129.201.248:3389 supports ENCRYPTION_METHOD_40BIT     : FALSE
[-] 10.129.201.248:3389 supports ENCRYPTION_METHOD_128BIT    : FALSE
[-] 10.129.201.248:3389 supports ENCRYPTION_METHOD_56BIT     : FALSE
[-] 10.129.201.248:3389 supports ENCRYPTION_METHOD_FIPS      : FALSE

[+] Summary of security issues

rdp-sec-check v0.9-beta completed at Sun Nov  7 16:50:33 2021
```

Authentication and connection to such RDP servers can be made in several ways. For example, we can connect to RDP servers on Linux using **xfreerdp**, **rdesktop**, or **Remmina** and interact with the GUI of the server accordingly.

Initiate an RDP Session

Initiate an RDP Session

```
[16:37:47:135] [95319:95320] [INFO][com.freerdp.core] - freerdp_connect:freerdp_set_last_error_ex resetting error  
[16:37:47:135] [95319:95320] [INFO][com.freerdp.client.common.cmdline] - loading channelEx rdpsnd  
[16:37:47:135] [95319:95320] [INFO][com.freerdp.client.common.cmdline] - loading channelEx rdpdr  
[16:37:47:135] [95319:95320] [INFO][com.freerdp.client.common.cmdline] - loading channelEx cliprdr  
[16:37:47:447] [95319:95320] [INFO][com.freerdp.primitives] - primitives autodetect, using optimized  
[16:37:47:453] [95319:95320] [INFO][com.freerdp.core] - freerdp_tcp_is_hostname_resolvable:freerdp_set_last_error  
[16:37:47:453] [95319:95320] [INFO][com.freerdp.core] - freerdp_tcp_connect:freerdp_set_last_error_ex resetting e  
[16:37:47:523] [95319:95320] [INFO][com.freerdp.crypto] - creating directory /home/cry0l1t3/.config/freerdp  
[16:37:47:523] [95319:95320] [INFO][com.freerdp.crypto] - creating directory [/home/cry0l1t3/.config/freerdp/cert  
[16:37:47:523] [95319:95320] [INFO][com.freerdp.crypto] - created directory [/home/cry0l1t3/.config/freerdp/serve  
[16:37:47:599] [95319:95320] [WARN][com.freerdp.crypto] - Certificate verification failure 'self signed certifica  
[16:37:47:599] [95319:95320] [WARN][com.freerdp.crypto] - CN = ILF-SQL-01  
[16:37:47:600] [95319:95320] [ERROR][com.freerdp.crypto] - @@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@  
[16:37:47:600] [95319:95320] [ERROR][com.freerdp.crypto] - @ WARNING: CERTIFICATE NAME MISMATCH!  
[16:37:47:600] [95319:95320] [ERROR][com.freerdp.crypto] - @@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@  
[16:37:47:600] [95319:95320] [ERROR][com.freerdp.crypto] - The hostname used for this connection (10.129.201.248:  
[16:37:47:600] [95319:95320] [ERROR][com.freerdp.crypto] - does not match the name given in the certificate:  
[16:37:47:600] [95319:95320] [ERROR][com.freerdp.crypto] - Common Name (CN):  
[16:37:47:600] [95319:95320] [ERROR][com.freerdp.crypto] - ILF-SQL-01  
[16:37:47:600] [95319:95320] [ERROR][com.freerdp.crypto] - A valid certificate for the wrong name should NOT be t  
  
Certificate details for 10.129.201.248:3389 (RDP-Server):  
Common Name: ILF-SQL-01  
Subject: CN = ILF-SQL-01  
Issuer: CN = ILF-SQL-01  
Thumbprint: b7:5f:00:ca:91:00:0a:29:0c:b5:14:21:f3:b0:ca:9e:af:8c:62:d6:dc:f9:50:ec:ac:06:38:1f:c5:d6:a9
```

The above X.509 certificate could not be verified, possibly because you do not have the CA certificate in your certificate store, or the certificate has expired.

Please look at the OpenSSL documentation on how to add a private CA to the store.

```
[16:37:48:801] [95319:95320] [INFO][com.winpr.sspi.NTLM] - VERSION = {
[16:37:48:801] [95319:95320] [INFO][com.winpr.sspi.NTLM] -     ProductMajorVersion: 6
[16:37:48:801] [95319:95320] [INFO][com.winpr.sspi.NTLM] -     ProductMinorVersion: 1
[16:37:48:801] [95319:95320] [INFO][com.winpr.sspi.NTLM] -     ProductBuild: 7601
[16:37:48:801] [95319:95320] [INFO][com.winpr.sspi.NTLM] -     Reserved: 0x000000
```

WinRM

Another component that fits WinRM for administration is Windows Remote Shell (**WinRS**), which lets us execute arbitrary commands on the remote system. The program is even included on Windows 7 by default. Thus, with WinRM, it is possible to execute a remote command on another server.

Footprinting the Service

As we already know, WinRM uses TCP ports 5985 (HTTP) and 5986 (HTTPS) by default, which we can scan using Nmap. However, often we will see that only HTTP (TCP 5985) is used instead of HTTPS (TCP 5986).

Nmap WinRM

```
Nmap WinRM

dbcyph0n@htb[/htb]$ nmap -sV -sC 10.129.201.248 -p5985,5986 --disable-arp-ping -n

Starting Nmap 7.92 ( https://nmap.org ) at 2021-11-06 16:31 CET
Nmap scan report for 10.129.201.248
Host is up (0.030s latency).

PORT      STATE SERVICE VERSION
5985/tcp  open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.34 seconds
```

If we want to find out whether one or more remote servers can be reached via WinRM, we can easily do this with the help of PowerShell. The [Test-WsMan](#) cmdlet is responsible for this, and the host's name in question is passed to it. In Linux-based environments, we can use the tool called [evil-winrm](#), another penetration testing tool designed to interact with WinRM.

```
Nmap WinRM

dbcyph0n@htb[/htb]$ evil-winrm -i 10.129.201.248 -u Cry0l1t3 -p P455w0rD!

Evil-WinRM shell v3.3

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimple
Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#Remote-path-comple
Info: Establishing connection to remote endpoint

*Evil-WinRM* PS C:\Users\Cry0l1t3\Documents>
```

WMI

Windows Management Instrumentation ([WMI](#)) is Microsoft's implementation and also an extension of the Common Information Model ([CIM](#)), core functionality of the standardized Web-Based Enterprise Management ([WBEM](#)) for the Windows platform. WMI allows read and write access to almost all settings on Windows systems. Understandably, this makes it the most critical interface in the Windows environment for the administration and remote maintenance of Windows computers, regardless of whether they are PCs or servers. WMI is typically accessed via PowerShell, VBScript, or the Windows Management Instrumentation Console ([WMIC](#)). WMI is not a single program but consists of several programs and various databases, also known as repositories.

Footprinting the Service

The initialization of the WMI communication always takes place on [TCP](#) port [135](#), and after the successful establishment of the connection, the communication is moved to a random port. For example, the program [wmiexec.py](#) from the Impacket toolkit can be used for this.

WMIexec.py

```
WMIexec.py
```

```
dbcyp0n@htb[/htb]$ /usr/share/doc/python3-impacket/examples/wmiexec.py Cry01t3:"P455w0rD!"@10.129.201.248 "host"
Impacket v0.9.22 - Copyright 2020 SecureAuth Corporation

[*] SMBv3.0 dialect used
ILF-SQL-01
```

Again, it is necessary to mention that the knowledge gained from installing these services and playing around with the configurations on our own Windows Server VM for gaining experience and developing the functional principle and the administrator's point of view cannot be replaced by reading manuals. Therefore, we strongly recommend setting up your own Windows Server, experimenting with the settings, and scanning these services repeatedly to see the differences in the results.

- Cheat Sheet
- Resources

Table of Contents

Introduction

- Enumeration Principles
- ✔
- Enumeration Methodology
- ✔

Infrastructure Based Enumeration

- Domain Information
- ✔
- Cloud Resources
- ✔
- Staff
- ✔

Host Based Enumeration

- FTP
- ✔
- SMB
- ✔
- NFS
- ✔
- DNS
- ✔
- SMTP
- ✔
- IMAP / POP3
- ✔
- SNMP
- ✔
- MySQL
- ✔
- MSSQL
- ✔
- Oracle TNS
- ✔
- IPMI
- ✔

Remote Management Protocols

- Linux Remote Management Protocols
- ✔
- Windows Remote Management Protocols

Skills Assessment

-  Footprinting Lab - Easy
-  Footprinting Lab - Medium
-  Footprinting Lab - Hard

My Workstation

OFFLINE

 Start Instance

∞ / 1 spawns left